

Easy Presentation Script

IT Security Threats & Countermeasures – Lanka Retail Solutions (LRS)

Simple speaking script for approximately a 10-minute presentation

Slide 1 – Introduction

Good morning everyone. Today I am going to present an IT security assessment for Lanka Retail Solutions, or LRS. I will explain the main security threats affecting the company and discuss suitable security solutions to reduce these risks.

Slide 2 – LRS Security Environment

LRS is a medium-sized retail company in Sri Lanka. It has 12 retail branches, two warehouses and a head office, with around 450 employees. The company uses many IT systems, such as POS, ERP, HR systems, email, online shopping and warehouse systems. Because the company depends heavily on IT, security is very important.

Slide 3 – Key Security Risks

There are several security risks affecting LRS. These include phishing attacks, weak passwords, missing multi-factor authentication, outdated operating systems and excessive user access. There are also problems with remote access, network separation, backups and security monitoring. These weaknesses could allow attackers to access important company systems.

Slide 4 – Recent Phishing Incident

LRS recently experienced a phishing incident. An employee received an email that looked like it came from a real supplier. The employee clicked the link and entered their username and password on a fake website. The attacker then obtained access to the account and tried to access internal systems. This shows why employee awareness and technical controls such as MFA are important.

Slide 5 – Effectiveness of Current Controls

LRS already has some security controls. These include passwords, antivirus, firewalls, CCTV, access cards, backups and VPN access. However, many of these controls have not been properly reviewed or tested for several years. So, the main problem is not that LRS has no security controls, but that some controls may not be strong or consistent enough.

Slide 6 – Network Monitoring

Network monitoring can help LRS detect suspicious activity. For example, it can identify unusual logins, repeated failed login attempts or unusual network traffic. It can also help the IT team investigate security incidents. Better monitoring would give LRS a clearer picture of what is happening across its network.

Slide 7 – Firewall Misconfiguration

A firewall controls network traffic entering and leaving the organisation. If firewall rules are configured incorrectly, attackers may gain access to systems that should be protected. LRS has not reviewed its firewall rules recently. Therefore, the company should regularly review and test its firewall rules and only allow necessary traffic.

Slide 8 – VPN Misconfiguration

A VPN allows authorised employees to access company systems remotely. However, if VPN access is too broad or poorly protected, it can create a security risk. LRS should use multi-factor authentication and only give employees access to the systems they actually need. Remote access should also be monitored.

Slide 9 – DMZ

A DMZ is a separate network area used for systems that need to be accessible from the Internet. For LRS, the online shopping platform could be placed in a DMZ. This helps separate the public-facing system from important internal systems. If the online platform is attacked, the attacker would have more difficulty reaching the internal network.

Slide 10 – Static IP

A Static IP address means that a device or server keeps the same IP address. This can be useful for important servers and network devices. It makes these devices easier to identify and can make firewall rules and monitoring easier to manage. However, a Static IP by itself does not provide security.

Slide 11 – NAT

NAT stands for Network Address Translation. It allows private internal IP addresses to communicate with the Internet using public IP addresses. This helps separate the internal network from the public Internet. NAT can support network security, but it should be used together with proper firewall controls.

Slide 12 – Risk Management

LRS should use a structured risk-management process. First, identify the risks. Then analyse their likelihood and impact. After that, evaluate and prioritise the risks. The organisation can then treat the risks and continuously monitor them. This gives LRS a clear and organised way to manage security problems.

Slide 13 – Physical Security

Physical security is also important for protecting IT systems. LRS already uses CCTV, access cards and controls around the server room. These measures help prevent unauthorised people from accessing important equipment. LRS should regularly review these controls and also consider protection against physical damage and environmental problems.

Slide 14 – Technical Security Measures

LRS should improve its technical security using several controls together. These include multi-factor authentication, network segmentation, endpoint protection, software updates, firewall reviews and network monitoring. Backups should also be separated from the production network. These controls can reduce the chance of an attack and also reduce the damage if an attack happens.

Slide 15 – Conclusion

To conclude, LRS already has several security controls, but there are still important weaknesses. The recent phishing incident showed weaknesses in account security and access control. LRS should improve MFA, network segmentation, monitoring, firewall and VPN security, backups and incident response. These improvements can help protect the confidentiality, integrity and availability of the company's information and systems. Thank you for listening.

Easy Presentation Script

IT Security Threats & Countermeasures – Lanka Retail Solutions (LRS)

Simple speaking script for approximately a 10-minute presentation

Slide 1 – Introduction

Good morning everyone. Today I am going to present an IT security assessment for Lanka Retail Solutions, or LRS. I will explain the main security threats affecting the company and discuss suitable security solutions to reduce these risks.

Slide 2 – LRS Security Environment

LRS is a medium-sized retail company in Sri Lanka. It has 12 retail branches, two warehouses and a head office, with around 450 employees. The company uses many IT systems, such as POS, ERP, HR systems, email, online shopping and warehouse systems. Because the company depends heavily on IT, security is very important.

Slide 3 – Key Security Risks

There are several security risks affecting LRS. These include phishing attacks, weak passwords, missing multi-factor authentication, outdated operating systems and excessive user access. There are also problems with remote access, network separation, backups and security monitoring. These weaknesses could allow attackers to access important company systems.

Slide 4 – Recent Phishing Incident

LRS recently experienced a phishing incident. An employee received an email that looked like it came from a real supplier. The employee clicked the link and entered their username and password on a fake website. The attacker then obtained access to the account and tried to access internal systems. This shows why employee awareness and technical controls such as MFA are important.

Slide 5 – Effectiveness of Current Controls

LRS already has some security controls. These include passwords, antivirus, firewalls, CCTV, access cards, backups and VPN access. However, many of these controls have not been properly reviewed or tested for several years. So, the main problem is not that LRS has no security controls, but that some controls may not be strong or consistent enough.

Slide 6 – Network Monitoring

Network monitoring can help LRS detect suspicious activity. For example, it can identify unusual logins, repeated failed login attempts or unusual network traffic. It can also help the IT team investigate security incidents. Better monitoring would give LRS a clearer picture of what is happening across its network.

Slide 7 – Firewall Misconfiguration

A firewall controls network traffic entering and leaving the organisation. If firewall rules are configured incorrectly, attackers may gain access to systems that should be protected. LRS has not reviewed its firewall rules recently. Therefore, the company should regularly review and test its firewall rules and only allow necessary traffic.

Slide 8 – VPN Misconfiguration

A VPN allows authorised employees to access company systems remotely. However, if VPN access is too broad or poorly protected, it can create a security risk. LRS should use multi-factor authentication and only give employees access to the systems they actually need. Remote access should also be monitored.

Slide 9 – DMZ

A DMZ is a separate network area used for systems that need to be accessible from the Internet. For LRS, the online shopping platform could be placed in a DMZ. This helps separate the public-facing system from important internal systems. If the online platform is attacked, the attacker would have more difficulty reaching the internal network.

Slide 10 – Static IP

A Static IP address means that a device or server keeps the same IP address. This can be useful for important servers and network devices. It makes these devices easier to identify and can make firewall rules and monitoring easier to manage. However, a Static IP by itself does not provide security.

Slide 11 – NAT

NAT stands for Network Address Translation. It allows private internal IP addresses to communicate with the Internet using public IP addresses. This helps separate the internal network from the public Internet. NAT can support network security, but it should be used together with proper firewall controls.

Slide 12 – Risk Management

LRS should use a structured risk-management process. First, identify the risks. Then analyse their likelihood and impact. After that, evaluate and prioritise the risks. The organisation can then treat the risks and continuously monitor them. This gives LRS a clear and organised way to manage security problems.

Slide 13 – Physical Security

Physical security is also important for protecting IT systems. LRS already uses CCTV, access cards and controls around the server room. These measures help prevent unauthorised people from accessing important equipment. LRS should regularly review these controls and also consider protection against physical damage and environmental problems.

Slide 14 – Technical Security Measures

LRS should improve its technical security using several controls together. These include multi-factor authentication, network segmentation, endpoint protection, software updates, firewall reviews and network monitoring. Backups should also be separated from the production network. These controls can reduce the chance of an attack and also reduce the damage if an attack happens.

Slide 15 – Conclusion

To conclude, LRS already has several security controls, but there are still important weaknesses. The recent phishing incident showed weaknesses in account security and access control. LRS should improve MFA, network segmentation, monitoring, firewall and VPN security, backups and incident response. These improvements can help protect the confidentiality, integrity and availability of the company's information and systems. Thank you for listening.

You have recently been appointed as a **Junior Cyber Security Consultant** at **SecureNet Consulting Services (SCS)**, an organisation that provides IT security assessment, network security, risk management, and cybersecurity consultancy services to businesses. As part of your role, you have been assigned to conduct a security assessment of **Lanka Retail Solutions (LRS)**, a medium-sized retail organisation operating across Sri Lanka.

LRS operates **12 retail branches, two warehouses, and a central head office**, and employs approximately **450 staff members**. The organisation has approximately **35,000 registered customers** and generates annual revenue of approximately **LKR 850 million**. LRS also operates an online shopping platform through which customers can purchase products. Due to the organisation's dependence on information technology, the availability, confidentiality, and integrity of its IT systems are important to its day-to-day business operations.

LRS uses a number of IT systems to support its business activities. These include a **Customer Database Server** containing customer contact details, addresses and purchase information; **Point-of-Sale (POS) systems** used by the retail branches to process transactions; an **Enterprise Resource Planning (ERP) system** used for finance, purchasing, inventory and supplier management; a **Human Resource Management system** containing employee and payroll information; an **email platform** used for internal and external communication; an **online shopping platform** used to process customer orders and online payments; a **Warehouse Management System** used to manage stock receiving, storage and distribution; and a **central file server** containing business documents and operational information. Selected employees can also remotely access some internal systems when working outside the organisation. These systems are connected through the organisation's internal network and therefore a security weakness in one system could potentially affect other systems.

LRS has implemented several basic security controls, including username and password authentication, antivirus software, firewall protection, CCTV cameras, access cards, weekly data backups, an employee Acceptable Use Policy, separate Wi-Fi networks for staff and customers, VPN access for selected remote employees, and physical security controls around the main server room. However, the organisation's management has recently become concerned that many of these controls have not been formally reviewed or tested for several years.

An internal security review identified a number of weaknesses within the current environment. Some employees continue to use weak passwords, while multi-factor authentication has not been implemented across all critical systems. Several computers are operating with outdated operating systems, and the organisation's firewall rules have not been reviewed regularly. Employees are also permitted to connect some personal devices to the corporate network. Remote access controls are not consistently applied, and network monitoring capabilities are limited. The organisation's backup systems are mainly connected to the same internal network as the production systems. In addition, LRS does not currently have a formal Disaster Recovery Plan or a structured incident response procedure. Security awareness training is provided to employees only occasionally, and

the organisation has not completely separated staff network traffic from customer or guest traffic. Security incidents are currently recorded manually, making it difficult for management to obtain a complete overview of security events.

The security weaknesses became more apparent following a **recent cybersecurity incident** involving the finance department. A finance employee received an email that appeared to have been sent by a legitimate supplier. The email requested the employee to confirm an invoice by clicking a link. The employee followed the link and entered their company username and password into a fraudulent login page. The attacker subsequently obtained access to the employee's account.

The compromised account was then used to attempt access to internal resources and to send similar phishing emails to other employees. LRS's IT team eventually identified unusual login activity and began investigating the incident. The investigation revealed that the affected account did not have multi-factor authentication enabled. It also identified weaknesses in network monitoring, excessive user access privileges, broad remote access permissions, and insufficient restrictions between some internal systems. The investigation further showed that firewall rules had not been reviewed recently and that backup systems were connected to the production network. The organisation also lacked a clearly defined incident response process, and responsibilities for dealing with security incidents were not clearly assigned between IT staff, HR, and senior management.

LRS was able to contain the incident before significant customer information was compromised. However, senior management recognises that a similar incident could have a much greater impact on the organisation. A successful attack could interrupt retail operations, affect the online shopping platform, expose confidential customer or employee information, cause financial losses, result in legal or regulatory consequences, and damage the organisation's reputation.

Following the incident, the **Board of Directors of LRS has requested an independent review of the organisation's IT security environment**. SCS has been asked to investigate the current security arrangements and provide recommendations that are appropriate for the organisation's size, business activities, financial position, and dependence on IT systems.

As the Junior Cyber Security Consultant responsible for the initial assessment, you are required to investigate the security risks affecting LRS and prepare recommendations for senior management. Your investigation should consider the organisation's existing security controls, network architecture, remote access arrangements, information systems, employees, physical facilities, and business operations. You should identify potential threats and vulnerabilities, assess the possible impact of these risks, and recommend appropriate security controls that could reduce the risks.

You should also consider how technologies such as **firewalls, VPNs, network monitoring systems, DMZs, Static IP addressing, Network Address Translation (NAT), intrusion detection and prevention systems, endpoint protection, access control, encryption, multi-factor authentication, network segmentation, and secure backup solutions** could be applied to the LRS environment. Your recommendations should consider both technical and non-technical

security measures and should explain how the proposed controls could improve the confidentiality, integrity, availability, and resilience of LRS's IT infrastructure.

Task 1 – IT Security Threat and Countermeasure Presentation

Prepare a professional presentation with supporting speaker notes for the senior management team of SecureNet Consulting Services.

Your presentation should analyse the IT security threats faced by LRS and recommend suitable security solutions.

The presentation should include:

- Critically discuss different types of security risks that may affect LRS, such as: Use appropriate examples related to the LRS scenario.
- Assess the effectiveness of LRS's current security procedures.
- Analyse the benefits of implementing network monitoring systems.
- Discuss the potential impact of incorrectly configured: Firewall policies, VPN services, Provide examples relevant to LRS.
- Using suitable examples, explain how the implementation of the following can improve network security: DMZ, Static IP, Network Address Translation (NAT)

Explain how each technology could be applied to the LRS network.

- Propose a suitable method that LRS could use to: Identify risks, Analyse risks, Evaluate risks, Prioritise risks, Treat risks, Monitor risks.
- Critically evaluate a range of Physical security measures and Virtual/technical security measures. Explain how these measures contribute to organisational security and resilience.

Submission Format

A formal 10-minute presentation consisting of approximately 10–20 slides, supported by speaker notes.

The presentation should be understandable to a non-technical management audience.

Pearson BTEC Level 5 Higher National Diploma in Software Engineering/ Network Engineering – [Weekend]

PP Effective From: 27th November 2025 to 15th December 2025

Intake Starting Date: 25th January 2026

Option 02: Interest Free Monthly Payments

<u>Instalment</u>	<u>Saegis</u>	<u>Due date</u>
Saegis Course Fee	Rs. 350,000	
Saegis Registration Fee	Rs. 25,000	Before the Commencement
Pearson Enrolment Fee – 1st Instalment**	£ 147**	Within 07 days from the offer letter received
Pearson Enrolment Fee – 2nd Instalment**	£ 147**	Within 1 Month from the Commencement
Saegis Course Fee - 1 st Instalment	Rs. 17,500	10 th February 2026
Saegis Course Fee - 2 nd Instalment	Rs. 17,500	10 th March 2026
Saegis Course Fee - 3 rd Instalment	Rs. 17,500	10 th April 2026
Saegis Course Fee - 4 th Instalment	Rs. 17,500	10 th May 2026
Saegis Course Fee - 5 th Instalment	Rs. 17,500	10 th June 2026
Saegis Course Fee - 6 th Instalment	Rs. 17,500	10 th July 2026
Saegis Course Fee - 7 th Instalment	Rs. 17,500	10 th August 2026
Saegis Course Fee - 8 th Instalment	Rs. 17,500	10 th September 2026
Saegis Course Fee - 9 th Instalment	Rs. 17,500	10 th October 2026
Saegis Course Fee - 10 th Instalment	Rs. 17,500	10 th November 2026
Saegis Course Fee - 11 th Instalment	Rs. 17,500	10 th December 2026
Saegis Course Fee - 12 th Instalment	Rs. 17,500	10 th January 2027
Saegis Course Fee - 13 th Instalment	Rs. 17,500	10 th February 2027
Saegis Course Fee - 14 th Instalment	Rs. 17,500	10 th March 2027
Saegis Course Fee - 15 th Instalment	Rs. 17,500	10 th April 2027
Saegis Course Fee - 16 th Instalment	Rs. 17,500	10 th May 2027
Saegis Course Fee - 17 th Instalment	Rs. 17,500	10 th June 2027
Saegis Course Fee - 18 th Instalment	Rs. 17,500	10 th July 2027
Saegis Course Fee - 19 th Instalment	Rs. 17,500	10 th August 2027
Saegis Course Fee - 20 th Instalment	Rs. 17,500	10 th September 2027

****There will be 5% processing fee on Pearson Enrolment Fee**

*****Terms & conditions applied**

IMPORTANT

1. If the intake commencement date is changed, the due dates will be changed accordingly.
2. This Section is applicable **ONLY** for the students who enrolled for the programs offered from Canterbury Christ Church University, UK.
 - a. There will be a 5% processing fee charging on the GBP amount.
 - b. The students those who wish to pay CCCU Payment via LKR, they can pay to Saegis Campus Cashier or via Direct Online Fund Transfer to Saegis Bank Account given below before the deadline. (Please make sure to get the Foreign Currency Exchange Rate from the

cashier/finance of Saegis Campus on the date of payment. Other rates will not be accepted, and processing fee will be charged).

- c. *The students those who wish to pay through the Bank Draft (BD) in GBP, they can handover a BD written in favour of “Canterbury Christ Church University, UK” in GBP Currency on or before the deadline to Saegis Cashiers with the BD processing fee of Rs. 15,000/=* and 5% processing fee on GBP will not be applied for the bank draft method. (change in rates will be informed to the student) *This must be for the full GBP amount*

3. This Section is applicable **ONLY** for the students who enrolled for the programs offered from Pearson, UK.

- a. *There will be a 5% processing fee charging on the GBP amount.*
- b. *The student **MUST** pay the Pearson Fee in LKR, to Saegis Campus Cashier or via Direct Online Fund Transfer to Saegis Bank Account given below before the deadline. (Please make sure to get the Foreign Currency Exchange Rate from the cashier/finance of Saegis Campus on the date of payment). Other rates are not valid or acceptable and processing fee will be charged.*
- c. *The bank drafts are not accepted by the campus.*

4. This section is applicable to all the students following any program offered by the affiliated foreign university.

The delay in affiliated university enrolment fee, will be subject to the following penalty charges and this will not be waiver under the any circumstances.

Affiliated Uni Enrolment 0 - 45 days after the deadline	Affiliated Uni Enrolment Fee x 1.25
Affiliated Uni Enrolment 46 - 90 days after the deadline	Affiliated Uni Enrolment Fee x 1.50
Affiliated Uni Enrolment 91+ days after the deadline	Affiliated Uni Enrolment Fee x 2

5. Payment Methods for Registration Fee / Saegis Course Fee / Affiliated University Fee

- a. Cash (LKR Only) or Card payments can be paid to the cashier counter at the ground floor. (Every day from 8.00am to 12.30pm and from 1.10pm to 4.00pm)
- b. Payments can be transferred / deposit to the following bank account.
 - o Bank Account Name : Saegis Campus (Pvt) Ltd.
 - o Bank Name & Branch : Commercial Bank PLC - Foreign Branch
 - o Bank Account Number : 1030030902

IMPORTANT: You MUST mention **Your Saegis ID Number in the BENEFICIARY REMARKS** of the Deposit Slip and You MUST SEND the Customer Copy of the Deposit Slip or the transfer slip ONLY to directdeposit@saegis.ac.lk with your details (Student’s Saegis ID, Student’s Name, Course/Programme, Payment Type – Registration Fee/Saegis Course Fee/Affiliated Uni Fee, Instalment Number) **within the same day of the Date of Deposit/transfer.**

6. Terms & Conditions and Collection Procedure

- a. You **must pay all fees on or before the due date mentioned** in the payment plan.
- b. Delayed payments or delays in sending online payment receipts will be surcharged with a **5% of monthly penalty charge** for the total outstanding amount in each month.
- c. A delay in payments for more than 4 weeks will be caused to block your LMS / Blackboard access where you cannot access the study materials or assignment submissions.
- d. A delay in payments for more than 8 weeks will be considered ‘withdrawn’ from the program and will be referring for the withdrawal process.
- e. Non-payment will be caused for not issuing the examination admissions and the results.

Saegis Campus

Payment Plan for January 2026 Intake – Early Bird



7. Refund Policy

- a. Saegis Registration Fee – Non -Refundable.
- b. Saegis Course Fee – 60% of the fee is non-refundable and Class fee is Non-Refundable after commencement of the semester. If you are paying monthly payments, then 60% of the Saegis Course Fee must be settled before withdrawing from the program if you are withdrawing after the semester commencement.
- c. Affiliated University Payment - Non- Refundable after registering to the affiliated university.

Please Note: A Refund Processing Fee of Rs. 10,000/= will be charged with every refund request.

8. **For Students Finance Related Inquiries**, please contact financeadmin@saegis.ac.lk or +9477 043 3934.

**Conditions apply.*

I confirm that I have read, understood, and agreed to the terms of this Payment Plan, including the payment amounts and due dates, prior to signing.

Student Full Name : _____

Student ID Number : _____

Signature of the Counsellor

Signature of the Student

Signature of the Parent

PROCESS REVIEW INTO DATA SECURITY

Wargrave College – Alternative Version

1. Introduction

Wargrave College is a sixth-form college with around 2,000 students and 65 staff. It holds a large amount of important information, including student records, medical and SEN information, attendance, assessment records, staff information, payroll data and emails. The college experienced a serious ransomware attack after a teacher downloaded malware while working from home. When the laptop was connected to the college network, the ransomware spread to network devices and encrypted the servers and backup NAS.

This process review examines the weaknesses in the college's existing risk assessment, explains appropriate data protection processes, recommends an ISO-based risk-management approach, considers the effects of an IT security audit and recommends how security should be aligned with organisational policy.

2. Review of Existing Risk Assessment

The current Wargrave College risk assessment classifies risks into three priorities. Priority 3 represents a critical risk requiring immediate action, Priority 2 represents a medium risk that can be addressed when funding is available, and Priority 1 represents a low risk that is considered unlikely.

Although several threats are listed, the assessment does not adequately reflect the actual business impact of a successful cyberattack. Staff laptop viruses were considered unlikely and given a low priority. This was particularly problematic because the actual ransomware attack started from a staff laptop.

The assessment also identified a major risk from a network DDoS attack but did not provide sufficient evidence of detailed treatment measures. The weekly backup arrangement was another major weakness because the single NAS backup was also encrypted by the ransomware.

The risk assessment should therefore be updated regularly and should consider assets, vulnerabilities, threats, likelihood, impact, existing controls, responsible owners and residual risk.

3. Data Protection Processes and Regulations

Wargrave College must protect personal and sensitive information throughout its lifecycle. The Student Information System contains contact details, medical information, assessment records, attendance and SEN information. HR systems contain staff and payroll information. Email systems also contain current and historical communications.

Effective data protection should include controlled access, strong authentication, appropriate encryption, secure storage, regular backups, monitoring and secure disposal of information when it is no longer required. Access should be limited to users who need information for their role.

The existing Acceptable Use Policy states that college IT facilities are subject to UK law and that network and email activity may be monitored for security and network-management purposes. However, the scenario indicates that staff were not previously covered by equivalent security policies. This creates an important weakness because staff use remote systems and can introduce threats into the college network.

The college should establish clear data-handling procedures, incident reporting processes, staff training and regular compliance reviews.

4. Recommended Risk Management Strategy

Wargrave College should introduce a formal risk-management process aligned with ISO/IEC 27001 principles. An Information Security Management System (ISMS) would provide a structured method for identifying information-security risks and continually improving security controls.

The process should begin by identifying important assets such as the SIS, HR servers, email services, file servers, VLP and backups. Threats and vulnerabilities should then be identified and assessed according to their likelihood and potential impact.

The college should assign an owner to every significant risk and select an appropriate treatment. High-priority risks should be reduced using controls such as network segmentation, secure remote access, endpoint protection, patch management, access controls, monitoring and resilient backups.

Risk assessments should be reviewed periodically and after major changes or security incidents. The ransomware incident should be used as a lessons-learned event to improve the risk process.

5. Impact of an IT Security Audit

An IT security audit would allow Wargrave College to determine whether its security controls are effective and whether employees are following the required procedures.

The audit should examine physical security, network architecture, firewall rules, VPN configuration, Remote Desktop access, server security, endpoint protection, software updates, user permissions, backup arrangements and security policies.

Based on the scenario, an audit would likely identify several weaknesses. Servers and network equipment were kept in an unsecured room, computers used an older operating system, staff could use Remote Desktop, a freeware VPN was being used and the backup system was not sufficiently protected against ransomware.

The audit could require financial investment and temporary disruption while improvements are implemented. However, it would reduce future risk by identifying vulnerabilities before attackers exploit them and would improve the college's ability to maintain teaching and remote-learning services.

6. Alignment with Organisational Policy

The current Acceptable Use Policy provides rules concerning inappropriate use of the college network. It prohibits unauthorised access, misuse of other users' accounts or files, deliberate data destruction, privacy violations and activities that disrupt network services.

The main weakness is that the policy is focused strongly on students. Staff were not considered a security threat and therefore did not have equivalent security requirements. This does not match the college's real operational risk, because the ransomware incident originated from a teacher's laptop.

The college should introduce a single security framework covering students, teachers, administrative staff, IT technicians and senior management. Remote workers should have clear requirements for VPN use, device security, software installation, password protection, reporting suspicious activity and handling sensitive information.

Misalignment between policy and actual practice can result in users ignoring security procedures, inconsistent controls, increased malware infections, data breaches and disruption to college operations.

7. Recommendations

- Review and update the risk assessment at regular intervals and after major incidents.
- Introduce an ISO/IEC 27001-aligned information-security management process.
- Extend security policies to all staff as well as students.
- Require authorised remote users to use secure VPN connections.
- Remove or restrict unnecessary direct Remote Desktop access.
- Implement stronger endpoint protection and regular security patching.
- Separate critical servers and sensitive systems from general user networks.
- Maintain protected, isolated and tested backups rather than relying on one NAS.
- Improve physical security around servers and network equipment.
- Introduce security monitoring and logging to detect suspicious activity.
- Provide regular cybersecurity awareness training.
- Establish a documented incident-response and recovery procedure.
- Conduct regular security audits and vulnerability assessments.

8. Conclusion

The existing risk assessment at Wargrave College did not accurately reflect the likelihood and consequences of modern cyber threats. The ransomware attack demonstrated that a threat originating from a staff device could affect the entire network and destroy both operational data and backups.

The college should adopt a structured ISO/IEC 27001-aligned approach that continuously identifies, assesses and treats information-security risks. Technical controls, physical security, staff policies, secure remote access, monitoring and resilient backups should work together.

Aligning security controls with organisational policy is also essential. The objective should be to protect confidential information, maintain the integrity of college systems and ensure that teaching and remote learning can continue even after a serious security incident.